PROJECT DEEP-DIVE & USER GUIDE

CryptPilot

Your money, explained. Every wallet, checked.

An AI personal-finance copilot (**FinPilot**) that forecasts your next 90 days, merged with a graph-verified Bitcoin wallet risk checker (**Cryptiq**), in one app.

What this document covers

1. The big picture: what CryptPilot is and why it exists
2. Architecture: the three services and why they are split
3. Tech stack: every major library and why it was chosen
4. Every feature, explained (FinPilot side)
5. Every feature, explained (Crypto side)
6. The AI layer: copilot, councils, RAG, safety
7. Sponsors & partner platforms: what, why, how, status
8. Full user walkthrough, step by step
9. Security & privacy design
10. Honest status, limitations & FAQ for judges
11. Glossary (Hinglish)

HINGLISH NOTE

Jahan concept thoda complicated hai, wahan aapko is orange box mein simple Hinglish explanation milega. Baaki document English mein hai taaki judges / teammates ko bhi easily samajh aaye.

Built from a full read of the `madhavzanwar/crypt-pilot` repository (code, docs, decisions log, audit notes) on 29 Oct 2026. Where the repository records a reason, this guide quotes it; where a reason is not written down, it is marked as *inferred*.

1 · The big picture

Most money apps look **backward**: they tell you where your money went. CryptPilot looks **forward** (what will happen to your cash in the next 90 days?) and it also checks **who you are about to pay** (is this crypto wallet connected to known illicit activity?).

Half	What it does	Core idea
FinPilot the copilot	Reads your accounts and transactions, scores your financial health on 5 pillars, simulates thousands of possible next months, and answers questions with facts from your own records.	"Forecast, don't just report."
Cryptiq the wallet guard	Paste a Bitcoin address and get **ALLOW / WARN / BLOCK / UNKNOWN**, a 0–100 risk score, the evidence graph around it, and a plain-language explanation in English or Hindi.	"Check before you send."

Why merge the two?

From `docs/CRYPTPILOT.md`: *"A person who manages money in one place also sends money to wallets they do not know. FinPilot knows the user's finances; Cryptiq knows whether a wallet is connected to addresses labelled illicit in a research graph."* Putting them together means the wallet check happens **exactly where the payment decision is made**: in the Copilot chat, in the Evidence Council, in the Risk Council and in the fraud (Twin) simulator.

> **HINGLISH MEIN SAMJHO**
>
> Socho aap ek app mein apna poora paisa manage karte ho (salary, EMI, SIP, kharche). Ab kisi ne bola "is Bitcoin address pe paise bhejo". Normal app ko pata hi nahi ki woh address safe hai ya fraud se juda hai. CryptPilot dono kaam ek jagah karta hai: aapka future cash-flow bhi batata hai, aur payment se **pehle** wallet ka "background check" bhi karta hai.

Target user

From `brand/BRIEF.md`: ambitious young Indian professionals, tech-forward earners and growing families. That is why the app has INR by default, Indian tax regimes, SIPs, mutual funds, UPI-style payment review, Account Aggregator (Setu) and a Hindi / Marathi UI.

Golden rule: test mode only

> Everything payment-related is **test mode or testnet only**. No real money moves. Dodo runs in `test_mode` (the service refuses any other value), Bitcoin uses testnet, Monero is a demo, and on-chain anchoring uses **Base Sepolia** (a testnet). Mainnet is not configured anywhere.

Three demo personas

The app runs with zero keys on seeded data: **Priya**, **Arjun** and **Meera** (each with 12 months of synthetic transactions, goals and debts; Priya also has a synthetic household: Rishi, Swara, Vedant). Press *"Explore Demo App"* on the login page and you are in.

2 · Architecture: three services

🖥️ Frontend · Next.js 16

React 19, Tailwind v4, Framer Motion, Recharts. All screens: Dashboard, Forecast, Copilot, Simulate, Wallet Guard, Statement, Credits… Talks only to same-origin `/api/*`.

⚙️ FinPilot API · FastAPI

Firebase token check, health score, Monte Carlo forecast, what-if engine, Copilot, Risk & Evidence councils, Chain Analyst, and the **/api/crypto bridge** (route allowlist).

🛡️ crypto-service (Cryptiq) · FastAPI

XGBoost risk scorer + graph features, TigerGraph / NetworkX graph engine, OFAC list, grounded LLM explainer, voice STT/TTS, credits ledger (Dodo, BTC, XMR).

Browser → Next.js (rewrites /api/*) → FinPilot API → Firestore

FinPilot API /api/crypto bridge → only `cryptiq_sid` cookie → crypto-service →

TigerGraph / NetworkX + labels + LLM

Why is the crypto-service a separate service?

- **Memory.** The scorer alone needs ~1 GB RAM; the NetworkX graph engine needs ~2.6 GB (823k wallets, 2.8M edges). A serverless function (Vercel) cannot hold that, so the crypto-service runs as its own container (laptop + Cloudflare tunnel, Fly.io, or any container host).
- **Security boundary.** FinPilot credentials must never reach the crypto code. The bridge forwards a fixed allowlist of routes and strips `Authorization` and FinPilot cookies.
- **Data licence.** Elliptic++ has no stated licence, so the dataset and model are not in git; the crypto container fetches them at start from a **private Hugging Face** repo.
- **Anonymous use.** Crypto routes use anonymous cookie sessions, so a visitor can check a wallet without signing in.

HINGLISH MEIN SAMJHO

Teen alag "dukaan" hain. **Frontend** = showroom jahan user aata hai. **FinPilot API** = main office jo aapke paise ka hisaab rakhta hai. **crypto-service** = alag security lab jo wallets check karti hai. Lab heavy hai (2.6 GB RAM), aur usse aapke bank wale secrets kabhi nahi milne chahiye, isliye beech mein ek "bridge" (gatekeeper) hai jo sirf allowed requests aage bhejta hai aur sirf crypto wala cookie pass karta hai.

Deployment plan

Piece	Where	Why
Frontend + FinPilot API	Vercel (one domain, `vercel.json` routes `/api/*` to Python)	Same origin = no CORS headaches, first-party cookies, free tier.
crypto-service	Docker container: laptop + `cloudflared` quick tunnel, or Fly.io (`fly.toml`)	Needs 1–2.6 GB RAM and a persistent SQLite ledger.
Data & model	Private Hugging Face dataset repo	Unlicensed research data must stay out of git and out of the public image.
User data	Firebase Firestore (or in-memory demo)	Per-user documents, security rules, free tier.

3 · Tech stack and why each piece

Technology	Used for	Why this one
Next.js 16 + React 19	The whole web app (App Router, ~37 routes)	Server rewrites let the browser call one origin; easy Vercel deploy; huge ecosystem.
Tailwind v4, shadcn/Radix UI	Design system, accessible components	Fast, consistent styling with brand tokens (Ink, Lime, Ember); Radix gives keyboard/ARIA for free.
Framer Motion, Recharts, NumberFlow	Animations, P10/P50/P90 charts, animated numbers	"Calm and reassuring" brand: smooth, readable money visuals.
react-force-graph-2d	Wallet evidence graph (1–3 hops)	Interactive, draggable graph to inspect neighbours.
wagmi, viem, RainbowKit, ethers, EAS SDK	Wallet connect + signing attestations on Base Sepolia	Standard Ethereum tooling; the user signs in their own wallet, no server key.
TanStack Query / Table, zod	Data fetching cache, transaction tables, validation	Reliable caching and typed validation.
FastAPI + Pydantic (×2 services)	Both backends	Python is where the data science lives (pandas, numpy, XGBoost); typed schemas = the "AnswerContract".
pandas, numpy, scipy	Health score, forecast bootstrap, graph features (PageRank) with sparse matrices	Fast vector maths; seeded so the same input gives the same output.
XGBoost + scikit-learn	Wallet risk model + isotonic calibration	Strong on tabular features, supports monotone constraints ("more flagged neighbours can never lower the risk").
NetworkX / pyTigerGraph	Graph engines (fallback / primary)	NetworkX works offline; TigerGraph scales k-hop queries.
SQLite + SQLAlchemy	crypto-service ledger, sessions, invoices	`BEGIN IMMEDIATE` transactions make credit charging atomic; tiny and disposable.
slowapi, sse-starlette	Rate limits, streaming progress steps	Abuse protection; live "checking graph… scoring…" steps.
RapidOCR (ONNX), CLIP via fastembed	Read receipts/statements, recognise items in photos	Runs on CPU, on the machine: no cloud needed for OCR (privacy).
Firebase (Auth + Firestore)	Google / email sign-in, persistence	See section 7.

4 · Features explained: FinPilot side

4.1 Dashboard & Financial Health Index

What: Balances, income, spending, budgets in one view, plus a 0–100 **Financial Health Index**.

How: `backend/app/analytics/health_score.py` combines five sub-scores:

Score = 0.30·Cash-flow + 0.25·Debt + 0.20·Savings + 0.15·Emergency fund + 0.10·Consistency

Why: The code comment says it plainly: *"this is a judged feature, so defensibility (a human can read the code and see exactly why the number is what it is) matters more than statistical sophistication."*

> **HINGLISH**
> Jaise school ka report card hota hai, waise hi paise ka report card. Paanch subjects: cash-flow stable hai ya nahi (30%), loan ka bojh (25%), saving ki aadat (20%), emergency fund kitne mahine chalega (15%), kharcha har mahine similar hai ya upar-neeche (10%). Sabka weighted total = aapka score.

4.2 Forecast & Risk (Monte Carlo)

What: A 90-day / multi-month cash-flow forecast with **P10 / P50 / P90** bands, the probability of a shortfall, scenario comparison and a backtest of the model's own accuracy.

How: `plan/forecast.py` uses a **joint month bootstrap**: for each of 2,000 seeded paths (configurable 500–10,000), each future month = recent median + a residual vector randomly drawn from your own history (income, essentials and discretionary drawn together so their correlation is kept). Shortfall probability = share of paths where cash falls below your reserve (`plan/risk.py`, no LLM).

Why: A single "average" line hides risk. Bands answer "what is the bad-but-realistic case?". Seeding makes results reproducible; the backtest proves the model is honest.

> **HINGLISH**
> Monte Carlo = ek hi future nahi, 2,000 "possible futures" banao. Har future mein aapke purane mahino jaisa random upar-neeche daalo. Phir dekho: 10% bure cases mein balance kitna (P10), beech wala (P50), aur ache 10% (P90). Agar 2,000 mein se 300 futures mein paisa reserve se neeche gaya, toh shortfall risk = 15%.

4.3 FinPilot Copilot (chat + voice)

What: Ask anything about your money ("Will I face a cash deficit in the next 90 days?"). Answers follow an **AnswerContract**: *facts from your records* are kept separate from *recommended actions*, each action has confidence and a simulated impact, and a one-click **"Test in What-If Simulator"**.

How: `copilot/engine.py` pre-fetches your real numbers via tool functions (`copilot/tools.py`: summary, spending breakdown, debt, forecast, affordability...) and sends them to an NVIDIA-hosted model; a NuGen model can give a second opinion; Firecrawl adds live web facts only when a gate decides the question needs it. If no key, or "offline mode", a **rule-based router** (`offline_router.py`) still builds a real answer from the same tools: no data leaves the server.

Extras: mic input (text lands in the box for you to edit, never auto-sent), and a wallet address typed in chat shows a wallet verdict card under it.

4.4 Simulate (What-If) & Recommendations

What: Flip subscriptions off "on paper", prepay a loan, raise a SIP, build an emergency fund, refinance, shift a payment date, check affordability. "You save" updates live and a 12-month chart shows compounding.

How: `simulate/engine.py` returns a real before/after forecast for each action. The recommendation engine (`recommend/engine.py`) actually *runs* the simulator for every candidate, so every suggestion carries a real impact number. Protected categories (needs like rent, groceries, medical) are never suggested for cuts.

> **HINGLISH**
> "Netflix band karun toh kya hoga?" Bina sach mein band kiye, simulator bata deta hai 12 mahine mein kitna bachega. Aur app kabhi nahi bolega "dawai ka kharcha kam karo"; zaroori cheezein protected list mein hain.

4.5 Statement (with SHA-256 audit hash)

A printable monthly health statement. Its audit hash is the real **SHA-256** of the canonical JSON of the printed figures (shown beside it so anyone can recompute it). Optional: **anchor it on Base Sepolia** via EAS (see section 7). Verified by `frontend/scripts/check-statement-hash.mjs`: 314 inputs, 0 mismatches.

> **HINGLISH**
> Hash = document ka "fingerprint". Ek bhi number badla toh fingerprint poora badal jayega. Isse koi baad mein statement mein chhed-chhaad nahi kar sakta bina pakde jaaye. Blockchain pe anchor karne se yeh proof milta hai ki yeh fingerprint is date ko exist karta tha.

4.6 Tax, Budgets, Goals, Household, Transactions, Connectors

- **Tax:** New regime (Sec 115BAC) vs old regime side by side, auto-detecting salary and deductions (80C, 80D, NPS 80CCD, HRA, 24b home loan) with what-if overrides.
- **Budgets:** envelope budgets with optional rollover of unspent surplus.
- **Goals:** targets with cover art, auto-track from a linked account, projected completion date and "on track" status.
- **Household:** invite partners (owner/editor/viewer, hashed invite tokens), family net worth, managed members such as children, fair-split of shared expenses.
- **Transactions:** filters plus a swipeable review deck; an always-on "watcher" reviews new transactions with simple rules and pops up insights.
- **Upload document / Photo prices:** OCR of statements and receipts on-device; personal data is **redacted first**; CLIP recognises items in a photo and suggests a price.
- **Connectors:** bank accounts, Google Sheets (live CSV sync), Gmail/Drive invoices, mutual funds (demo datasets), Account Aggregator (Setu), plus the Dodo and Cake Wallet payment rails.
- **Security / Profile / My Data:** TOTP MFA, an audit log of changes, data export; English / Hindi / Marathi UI with on-demand translation.

5 · Features explained: Crypto side (Cryptiq)

5.1 Wallet Guard

What: Paste or speak a Bitcoin address, get a verdict card (ALLOW / WARN / BLOCK / UNKNOWN), a 0–100 risk score, nearest flagged wallet, OFAC and Ransomwhere matches, an inspectable 1–3 hop evidence graph, and an explanation in English or Hindi with a "Listen" button.

The pipeline (`crypto-service/app/services/pipeline.py`):

Secret guard → Checksum → Credit gate → 10-min cache → Graph k-hop → XGBoost score → Verdict policy → Grounded explanation → Persist + charge

- **Secret guard:** if you paste a seed phrase (12+ BIP-39 words) or a private key, it is detected and cleared, never sent or logged.
- **Checksum:** base58check and bech32/bech32m (Taproot) validated in-house.
- **Model:** XGBoost on 55 wallet features + 9 graph features (PageRank, component size, flagged neighbours at hop 1 and 2, hops to nearest illicit). Calibrated so score ≈ probability ×100. BLOCK threshold = precision ≥ 90%, WARN = precision ≥ 50%.
- **Policy:** an OFAC sanctions hit always forces BLOCK; a wallet the dataset itself labels illicit is never ALLOW.
- **Explanation:** the LLM only sees whitelisted evidence. A validator checks every number appears in the evidence, bans words like "criminal", "scam", "safe wallet"; if it fails, a deterministic template is used.

> **HINGLISH**
> Bitcoin mein har wallet doosre wallets se transactions ke through juda hota hai, jaise ek bada social network. Agar aapka wallet 1 ya 2 "hop" door kisi illicit (gadbad) wallet se juda hai, toh risk badhta hai. Model yeh connections + wallet ka behaviour dekh ke score deta hai. **UNKNOWN ka matlab "safe" nahi hai**, iska matlab "humare dataset mein yeh wallet hai hi nahi".

5.2 Credits

1 credit per new check. Free: a repeat of the same wallet within 10 minutes (cache), any UNKNOWN result, any service error. 3 free credits per new session. Buy packs with a **Dodo** test card or a **Cake Wallet** BTC-testnet / Monero-demo invoice. The ledger is append-only and each payment can only be credited once (unique `(reason, ref)`), even if a webhook is repeated.

> **HINGLISH**
> Credits = wallet-check ke tokens. Sirf "kaam ka" naya result ho tabhi credit katta hai. Same payment ka webhook do baar aaye toh bhi credit ek hi baar milega (idempotency).

5.3 Chain Analyst (inside the councils)

The only council agent that does not read your finances. You list up to five public wallets you pay or hold; each is screened by the crypto-service. In the Evidence Council it is a 10th stage before the Risk Scorer; in the Risk Council it is an 8th specialist. It **abstains** when a wallet is UNKNOWN or the service is offline, and harmless findings never raise your risk score.

5.4 Voice

Mic in the Copilot and Wallet Guard. Order: **Wispr Flow → Sarvam → browser speech**. A chip shows who actually transcribed it. Spoken addresses ("capital A, small b, seven...", English and Hindi number words) are reconstructed and must pass the checksum. Sarvam TTS reads explanations aloud.

5.5 Benchmark: raw dump vs graph evidence

An experiment endpoint asking: is it cheaper and better to give an LLM a compact graph-evidence JSON than a raw dump of 300 edges? One earlier run (N=25) found graph evidence cheaper in tokens but less accurate on licit wallets: treated as an anecdote, not a result.

6 · The AI layer

6.1 Risk Council (7 + 1 agents)

Seven personas vote on how risky your finances are: **Strict Auditor, Cash-Flow Realist, Debt Hawk, Fraud Sentinel, Behavioural Coach, Growth Optimist, Peer Benchmarker** (+ **Chain Analyst** if you list wallets).

- They never see raw transactions, only a ~250-token facts JSON.
- Each answers with a score and one short reason; agents far from the median get a second turn after hearing the opposing argument (recorded dissent).
- Level and verdict are computed in code, not by a model. No key? Each agent falls back to a deterministic rule, so the council always convenes.

> **HINGLISH**
> Jaise ek panel of experts: ek strict CA, ek loan se darne wala, ek fraud expert, ek optimist... Sab apna vote dete hain. Jo bahut alag soch raha hai usse ek baar aur sochne ka mauka milta hai. Final faisla code karta hai, AI nahi, taaki result predictable rahe.

6.2 Evidence Council (9 + 1 stages)

Agents examine your ledger one after another and hand findings forward: Data Guardian, Duplicate Detector, Fraud Hunter, Merchant Verifier, Subscription Sleuth, Pattern Analyst (all deterministic, every finding links to the transactions behind it), then a Web Checker (live web on risky merchants), Risk Scorer (agents that flag the same merchant corroborate each other) and a Verdict Writer. Each rule agent gets an AI second opinion. Runs can be orchestrated by **Inngest** as durable background jobs.

6.3 Twin Simulator

Simulate a fraud attempt against your own spending pattern (optionally including a wallet) and see which categories and merchants would get flagged.

6.4 Hybrid RAG over your own data

`backend/app/rag` : your transactions and uploaded documents become "fact cards", indexed with **NVIDIA embeddings** (dense) + BM25 keywords, fused with Reciprocal Rank Fusion. The copilot answers from these retrieved facts.

> **HINGLISH**
> RAG = AI ko pehle aapke apne records mein se relevant cheezein "dhoondh ke" do, phir jawab banwao. Isse AI apni taraf se numbers nahi banata (hallucination kam). Do tareeke se dhoondhte hain: meaning se (embeddings) aur exact words se (BM25), phir dono list ko mila dete hain.

6.5 Anti-hallucination & cost discipline

- Numbers come from code; models only explain or judge.
- Strict JSON schemas, tight `max_tokens` , 10-minute caches on identical requests, cheap model for councils, deep model for money questions.
- Every AI call is logged (provider, model, latency, tokens; never the key) in a telemetry ring buffer.
- Always a fallback: offline router, deterministic council rules, template explanations.

7 · Sponsors & partner platforms

Important: the repository does not contain a written "sponsors" list. The platforms below are every third-party sponsor-style platform actually integrated in the code. The ones most prominently built into the product story (README badges, Connectors page, docs) are **TigerGraph, Dodo Payments, Cake Wallet, Sarvam, Wispr Flow, NVIDIA, NuGen** and **Base / EAS**. Please cross-check against your hackathon's official sponsor list and drop any that were not sponsors. Reasons quoted from docs are marked *(documented)*; others are *(inferred)* from how the code uses them.

🟢 TigerGraph (Savanna) graph database

What we added	A full graph engine: schema `Wallet(address, label, pagerank, comp_id, comp_size, in_deg, out_deg)` with directed `SENT_TO` edges in graph `Cryptiq`; GSQL queries `khop_exposure`, `wallet_summary`, `graph_stats`. Code: `crypto-service/app/services/graph/`.
Process	1) Process Elliptic++ CSVs into Parquet. 2) Compute PageRank and connected components offline with scipy. 3) `make load-graph` upserts 822,942 vertices and ~2.8M edges into Savanna. 4) `make install-queries`. 5) Cross-check against NetworkX (reported: 0 differences over 46 wallets). Connected via pyTigerGraph with a secret token and an 8 s client-side deadline.
Why chosen	Wallet risk is a *graph* problem ("how many hops to a flagged wallet?"). A native graph DB answers k-hop questions over millions of edges in ~670 ms without holding the graph in our own RAM (NetworkX needs 2.6 GB). *(documented)* Graph features are precomputed so the model and TigerGraph use identical numbers.
How it helps	Powers the evidence graph, nearest-illicit-hop, and the Chain Analyst. Lets the crypto-service run on a small 1–2 GB machine.
Status	Reported working by an earlier session; the Savanna workspace was suspended during the 29 Oct audit, so the app fell back to NetworkX. Resume it in the Savanna console before a demo.

HINGLISH

TigerGraph ek "graph database" hai: data ko table mein nahi, dots (wallets) aur lines (transactions) ki tarah store karta hai. "Is wallet se 2 kadam door kaun-kaun hai?" jaisa sawaal yeh bahut fast answer karta hai. Bina iske poora 2.6 GB graph humein apni RAM mein rakhna padta.

🟢 Dodo Payments `card checkout, test mode`

What we added	Credit packs bought by card: `POST /api/crypto/checkout` creates a Dodo checkout session; Dodo calls our webhook `/api/crypto/webhooks/dodo` on `payment.succeeded` (also refunds/disputes); credits are added to the ledger. Optional usage metering (`/events/ingest`). Shown as a "payment rail" on Connectors. Code: `crypto-service/app/services/billing/`.
Process	Create products in the Dodo test dashboard → put their ids in `PACKS_JSON` → set `DODO_API_KEY`, `DODO_WEBHOOK_SECRET` → point the webhook at the public URL. Implemented with plain httpx against the official SDK's endpoints; webhook signatures verified with **Standard Webhooks HMAC** (5-min tolerance, constant-time compare), each event id stored so duplicates are ignored.
Why chosen	Simple hosted checkout + webhooks + usage-based billing, with a real test mode, so the credits model is realistic without moving real money. *(inferred)* The code refuses any `DODO_ENV` other than `test_mode`.
How it helps	Makes Wallet Guard a sustainable pay-per-check product, not just a demo.
Status	Logic and signature checks unit-tested; never run live (needs the key and a public webhook URL). See `docs/GO_LIVE.md` step 2.

🟢 Cake Wallet `crypto payments, testnet`

What we added	Pay for credits with crypto: `POST /api/crypto/crypto-invoice` returns a `bitcoin:` (testnet) or `monero:` (demo) URI plus a QR code. The user scans it with their own Cake Wallet app. The page polls every 10 s; BTC payment is detected through an Esplora explorer (mempool.space testnet) by an exact amount (price + random 1–999 sat offset).
Process	Set `BTC_RECEIVE_ADDRESS` (testnet), `BTC_SATS_PER_USD`, `BTC_EXPLORER_BASE_URL` → open an invoice → pay from Cake Wallet → explorer sees the tx → credits added. Monero is marked paid by an admin endpoint (no auto-confirm).
Why chosen	Cake Wallet is a popular open-source, non-custodial wallet supporting both Bitcoin and Monero, matching a crypto-native audience. Non-custodial = the app never sees private keys; receive addresses are public. *(inferred; "the app never sees private keys" is documented)*
How it helps	Crypto users can pay in crypto; completes the "AI × crypto" story.
Status	Never run end to end (no test coins). XMR is demo only by design.

🟢 Sarvam AI `Indian-language voice`

What we added	Speech-to-text (`saaras` models) and text-to-speech (`bulbul` models) in the crypto-service: transcribe spoken questions/addresses, read wallet explanations aloud in English and Hindi. TTS audio is cached by content hash for 24 h.
Process	Set `SARVAM_API_KEY`, `SARVAM_STT_MODEL`, `SARVAM_TTS_MODEL`. Request/response shapes were verified against the official `sarvamai` SDK source. Audio is checked (type + magic bytes, ≤5 MB), converted with ffmpeg to 16 kHz mono WAV.
Why chosen	Built for Indian languages and accents; our users are Indian and the explanations are in Hindi. *(inferred)*
How it helps	Accessibility: users who prefer speaking Hindi can check a wallet or ask the copilot by voice and hear the answer.
Status	Reported working by an earlier session; not re-run in the audit.

🟢 Wispr Flow voice dictation

What we added	First choice for speech-to-text; any error falls through to Sarvam, then to the browser's Web Speech API. A chip shows "Wispr Flow" only when Wispr actually produced the text.
Process	Set `WISPR_API_KEY`; audio is sent as base64 16 kHz WAV.
Why chosen	High-accuracy dictation for messy spoken input like wallet addresses. *(inferred)*
Status	Never run: no key was available and the request shape is unverified (built from the brief). Optional, see GO_LIVE step 5.

🟢 NVIDIA (NIM hosted models) main AI brain

What we added	Almost all FinPilot AI: Copilot deep model (`nemotron-3-super-120b`) for money questions, fast chat model (`nemotron-3.5-lightning-30b`) for small talk and the 7-agent council, embeddings (`nemotron-3-embed-1b`, 2048-dim) for RAG, a Llama 3.2 vision model for bills/photos, Evidence Council second opinions and verdicts, the voice agent that navigates the screen, and translation fallback.
Process	Free key from build.nvidia.com → `NVIDIA_API_KEY` (optional separate keys per feature). OpenAI-compatible API, so a small httpx client; JSON-schema answers; the client raises so the engine can try a backup model.
Why chosen	Free hosted access to several model sizes (big, fast, embed, vision) behind one OpenAI-compatible API, so each agent can use the cheapest model that fits its job. *(inferred; per-agent model choice is documented)*
How it helps	Real AI answers with your real numbers; without it the app still works on the offline router.

🟢 NuGen second opinion LLM

What we added	`backend/app/copilot/nugen.py`: gets the same pre-fetched bundle of your real numbers and gives a short prose second opinion (default model Llama-3.2-3B-Instruct).
Why chosen	An independent model as a cross-check reduces single-model blind spots; it never raises, so it can only add value. *(inferred)*
Status	Optional (`NUGEN_API_KEY`).

🟢 Base Sepolia + Ethereum Attestation Service (EAS) on-chain proof, testnet

What we added	"Anchor this statement on-chain": the statement hash is attested on Base Sepolia (chain 84532) with schema `string subjectAddress, string chain, uint8 riskScore, string verdict, bytes32 reportHash`. Also "Verify a statement hash" (no wallet needed). Wallet verdicts can be attested too. Code: `frontend/lib/crypto/eas/`, `components/crypto/web3/`.
Process	Register the schema once on Base Sepolia → set `NEXT_PUBLIC_EAS_SCHEMA_UID` → user connects a wallet (RainbowKit/wagmi; WalletConnect optional) and signs in the browser. Only hashes, document type, period and score are published.
Why chosen	A public, tamper-proof timestamp for a report with no server key and near-zero cost on an L2 testnet. *(inferred; "no server holds a key" is documented)*
Status	Never run with a real wallet; a simulated preview works without the schema UID.

Other platforms integrated

Platform	What it does in CryptPilot	Why / status
Firebase (Google)	Google + email sign-in, Firestore per-user data, security rules; backend verifies Firebase ID tokens on every `user_id` route.	Free, fast auth + DB. Fixes an earlier IDOR bug. Project `cryptpilot-madhav-01`; scripts `setup_firebase.sh/.ps1`.
Google Gemini	First choice for photo recognition (bills, Photo prices) and UI translation to Hindi/Marathi; NVIDIA is the fallback.	Fast, cheap multimodal model; optional key.
Firecrawl	Live web search + scrape for copilot questions that need current facts, and the Evidence Council's Web Checker.	Gated (regex + cheap LLM) so it is only called when needed; 6 h cache, 20 calls/hour cap.
Tavily	Web search/extract/crawl proxy (Web Intel, scheme analyst) so the key never reaches the browser.	Backend routes kept; the Web Intel page was removed from the UI in the merge.
Inngest	Durable background orchestration of Evidence Council stages (parallel agents, retries, run dashboard).	Serverless functions time out; Inngest steps survive. Protected by `X-Job-Token`.
Setu (Account Aggregator)	Real Indian bank data via consent (FIU APIs) when `AA_PROVIDER=setu`; otherwise a spec-shaped mock (OTP 123456).	India's official consent-based bank data rail.
Resend	Optional "email me if a cash gap is coming" alert.	Simple email API; only on explicit button.
Hugging Face	Private dataset repo holding Elliptic++ data and the trained model, fetched at container start.	Keeps unlicensed data out of git.
Vercel / Cloudflare	Hosting the web + API; quick tunnel to expose the laptop-hosted crypto-service.	Free split deployment (GO_LIVE 0b).
OFAC / Ransomwhere / Elliptic++	Sanctions list (exact match forces BLOCK), optional ransomware list, research labels for the graph.	Public/research data sources, not sponsors.

Removed during the merge: Plaid (US/EU bank linking: off-theme and unconfigured) and the Google Pay / FinPilot Pay phone card (replaced by the Dodo + Cake Wallet rails).

8 · User walkthrough: step by step

This is how a real user (or a judge) moves through the app. It uses the demo data, so you can follow it without any keys.

1

Land on the homepage

The hero says "Your money, explained. Every wallet, checked." Two actions: **Check a wallet** and get started. A Wallet Guard section shows an illustrative example verdict.

2

Sign in, or explore the demo

On `/login`: **Sign in with Google**, email/password, or ⚡ **Explore Demo App (No Sign-In Required)**, which opens a seeded persona (Priya / Arjun / Meera). Wallet Guard works even without sign-in (anonymous session, 3 free credits).

3

Onboarding questionnaire

First login: pick your language (English / Hindi / Marathi), then one question per screen (role, goals…). Answers shape the dashboard (simple view, a role-based plan in "Role Spotlight").

> HINGLISH
> Pehli baar app kholte hi woh aapse chhote-chhote sawaal poochta hai (aap student ho, salaried ho, business ho…). Usi hisaab se dashboard aapke liye customise ho jata hai.

4

Connect your money

Go to **Connectors**. Link a bank (demo dataset or Setu AA consent), a Google Sheet, Gmail/Drive invoices or mutual funds. The app "starts empty and fills itself when a source is linked". Or upload a statement/receipt photo on **Upload document** (OCR on the server, personal data redacted first).

5

Read the Dashboard

See balances, income vs spend, budgets and your **Financial Health Index** with all five pillars. A Wallet Guard tile jumps to the crypto check.

6

Look ahead with Forecast & Risk

See the P10 / P50 / P90 bands for the coming months, the shortfall probability, risk factors and the backtest. Compare scenarios.

7

Ask the Copilot

Type or tap the mic: "Will I face any cash deficit in the next 90 days?". You get **facts from your records** and **recommended actions** with confidence and impact. Toggle offline mode if you want nothing to leave the server.

8

Test the advice in Simulate

Click **Test in What-If Simulator**: the action is prefilled. Toggle subscriptions, prepay a loan, raise a SIP; "You save" and the 12-month chart update live.

9

Plan: Budgets, Goals, Tax, Household

Set envelopes and goals (auto-track from an account), compare new vs old tax regime, invite your partner to the household.

10

Before paying a crypto wallet: Wallet Guard

Open **Wallet Guard**, paste or speak the address (or click a demo chip such as the **Block** example). Watch the progress steps, then read the verdict card, risk score, nearest flagged wallet, OFAC/Ransomwhere hits, and expand the evidence graph. Tap **Listen** for the Hindi/English explanation.

> HINGLISH
>
> Verdict kaise padhein: **ALLOW** = dataset mein dikkat nahi mili. **WARN** = thoda shak, dhyan se. **BLOCK** = flagged wallets ke bahut kareeb ya OFAC sanctioned, mat bhejo. **UNKNOWN** = humare paas iska data nahi, iska matlab safe NAHI hai. Galti se seed phrase paste kiya toh app usse turant mita deta hai.

11

Out of credits? Buy a pack

Open **Credits** (or the drawer). Pay with a Dodo test card (return to `/credits/success`) or create a Cake Wallet invoice and scan the QR with Cake Wallet (BTC testnet). The page polls and adds credits when payment is seen.

12

Security checks: Evidence Council, Risk Council, Twin

Run the **Evidence Council** to scan your ledger for duplicates, fraud patterns and unknown merchants; convene the **Risk Council** to see 7 experts vote (add your wallets for the Chain Analyst); use the **Twin Simulator** to rehearse a fraud attempt.

13

Get your monthly Statement

Open **Statement**, print or save it. Check the SHA-256 hash against the canonical JSON beside it. Optionally connect a wallet and **anchor it on Base Sepolia**, or paste a hash in "Verify a statement hash".

14

Keep it safe

Turn on **TOTP MFA** in Security, review the audit log, export or delete data in **My Data**, switch language any time.

9 · Security & privacy design

Protection	How it works
Per-user isolation	Every `user_id` route verifies the Firebase ID token and that its subject matches; Firestore rules keep documents private. Only the 3 public demo personas are reachable without a token.
Crypto boundary	Browser never talks to the crypto-service. Bridge forwards an explicit route allowlist and only the `cryptiq_sid` cookie; per-IP rate limit 30/min.
Seed-phrase guard	Real BIP-39 wordlist; zero-width tricks, full-width letters, "1. word 2. word" numbering do not bypass it. Applies to text and voice.
Offline mode	Copilot can answer from the deterministic rule router; your data never leaves the API process.
Redaction & on-device OCR	Statements are redacted before anything is stored; OCR and CLIP run locally on CPU.
Logs	Never contain full addresses (salted HMAC), request bodies, transcripts or secrets; telemetry records only the env-var name of a key.
Payments	Webhook HMAC verification, idempotent ledger, atomic credit charging (no double charge on concurrent checks), test mode enforced.
Prod guards	`APP_ENV=prod` refuses to start with placeholder secrets, insecure cookies, empty CORS or a missing OFAC list.
Other	TOTP MFA, audit log of mutations, CSV upload limits, body-size limits, security headers, `pip-audit` clean.

10 · Honest status, limitations & judge FAQ

What is verified

Area	Result
FinPilot backend tests	597 passed, 0 failed (latest integration run)
crypto-service tests	269 passed, 3 skipped
Frontend	`tsc` 0 errors, eslint 0 errors, `next build` passes (37 pages)
Statement hash	314 inputs, 0 mismatches vs Node crypto
Needs keys / funds (not run live)	Dodo checkout, BTC testnet invoice, EAS signing, Wispr Flow
Deployment	Not deployed yet

Limitations to state openly

- **Old data:** Elliptic++ covers roughly 2016–2018, so most wallets checked today return UNKNOWN. The live value today is mostly the OFAC list plus dataset hits.
- **A verdict is a risk signal, not an accusation.** Say "labelled illicit in the Elliptic++ research dataset".
- **WARN is a weak signal:** the graph model improves PR-AUC (0.434 vs 0.339) and BLOCK-level F1 (0.464 vs 0.167), but at the WARN threshold it flags ~25% of licit test wallets.
- Free LLM tiers rate-limit; explanations then fall back to templates (never an error).
- Crypto-service speaks English and Hindi (Marathi is sent as Hindi).
- Anonymous sessions can be reset for new free credits; a per-IP cap bounds it.

Likely judge questions

Question	Short answer
Why is the risk score trustworthy?	Time-based train/validation/test split, thresholds chosen on validation only, monotone constraints, calibration, and the explanation is validated against the evidence.
Does the AI make up numbers?	No: numbers come from code and your records; the model only explains. Validators and fallbacks catch drift.
What happens without any API key?	Everything still runs: offline copilot router, rule-based council, template explanations, NetworkX engine, demo data.
Why TigerGraph if NetworkX works?	NetworkX needs 2.6 GB in-process RAM; TigerGraph moves the graph out and serves k-hop queries at scale.
Is real money involved?	Never. Test mode / testnet only, enforced in code.

11 · Glossary (Hinglish)

Term	Simple meaning
Monte Carlo	Hazaaron random "possible futures" bana ke dekhna ki result ka range kya hai.
P10 / P50 / P90	10% bure cases ki line / beech wali line / 10% ache cases ki line.
Bootstrap	Apne hi purane data mein se random sample utha ke naye scenarios banana.
Hop	Ek wallet se doosre tak ek transaction ka kadam. 2 hops = dost ka dost.
k-hop query	"Is wallet se k kadam tak kaun-kaun juda hai?" yeh graph database se poochna.
PageRank	Network mein kaun kitna "important/central" hai, uska score (Google wala idea).
XGBoost	Bahut saare chhote decision trees ka group jo milke prediction karte hain.
Calibration	Score ko itna sahi banana ki "70" ka matlab sach mein ~70% chance ho.
OFAC	US government ki sanctions list. Is pe address mila toh seedha BLOCK.
Seed phrase	12–24 words jo aapke wallet ki master key hain. Kisi ko kabhi mat do; app inhe detect karke mita deta hai.
RAG	AI ko pehle aapke data se relevant facts dhoondh ke dena, phir jawab banwana.
Embeddings	Text ko numbers ki list mein badalna taaki "matlab" se search ho sake.
Hallucination	AI ka apni taraf se galat fact bana dena. Humara design isse rokta hai.
Webhook	Payment company khud humare server ko call karke batati hai "payment ho gaya".
Idempotency	Same request do baar aaye toh bhi effect ek hi baar ho (double credit nahi).
SHA-256 hash	Data ka unique fingerprint; ek digit badla toh fingerprint badal jata hai.
Attestation (EAS)	Blockchain pe ek signed "yeh hash is date ko tha" ka public record.
Testnet / Sepolia	Practice blockchain jahan coins ki koi real value nahi hoti.
Non-custodial wallet	Wallet jiski keys sirf aapke paas hain (jaise Cake Wallet), company ke paas nahi.
Account Aggregator	RBI-regulated system jisse aap consent dekar bank data share karte ho (Setu).
TOTP MFA	Authenticator app ka 6-digit code jo har 30 sec badalta hai: extra login security.

CryptPilot · MIT licence · Payments are test mode only. Generated from the repository state on 29 Oct 2026.